

UK GDPR Security Control Assessment

Executive report | MT-ENT-002 Meridian Trust Bank plc (fictional)

Portfolio Case Study - fictional/synthetic MTFS content only. Methodology demonstration; not a real client audit, certification audit, legal opinion or regulatory assurance engagement.

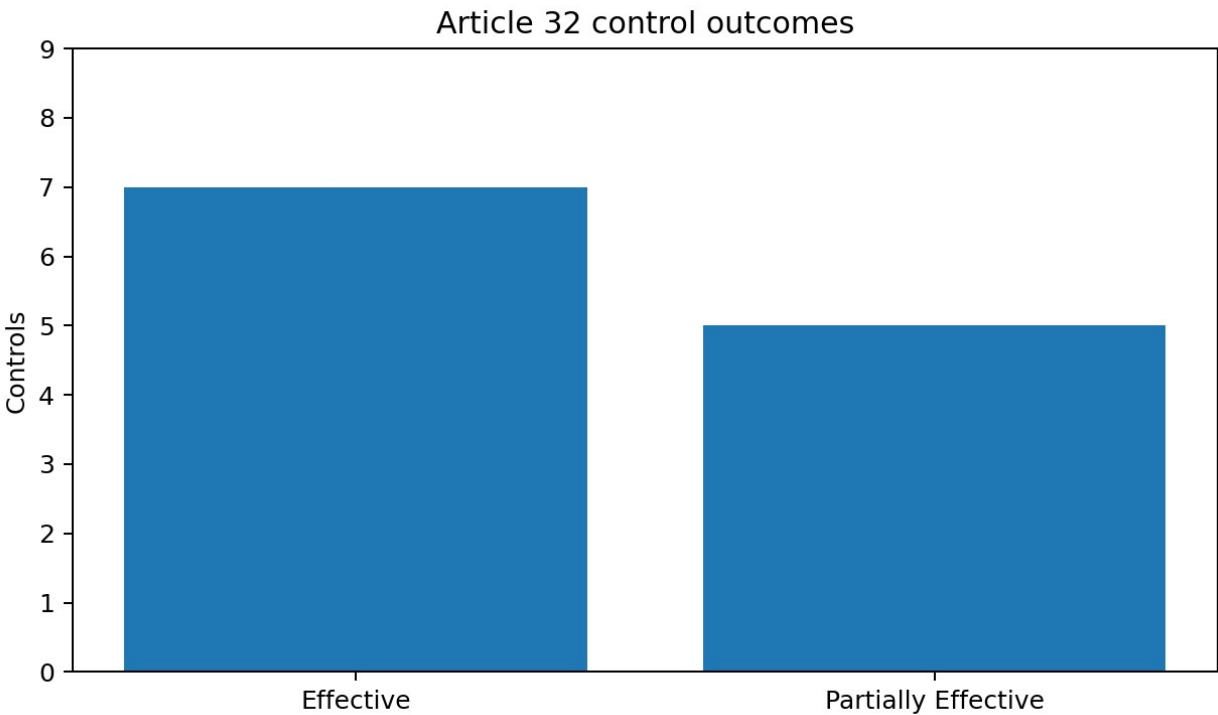
Overall conclusion

Needs improvement. The selected Article 32 security-control environment is broadly designed to address personal-data risk, but five operating/design weaknesses reduce assurance over privileged access, monitoring, recovery, processor oversight and vulnerability remediation. No conclusion is made on UK GDPR legal compliance as a whole.

12	7	5	5
control outcomes	effective	partially effective	findings

What matters to management

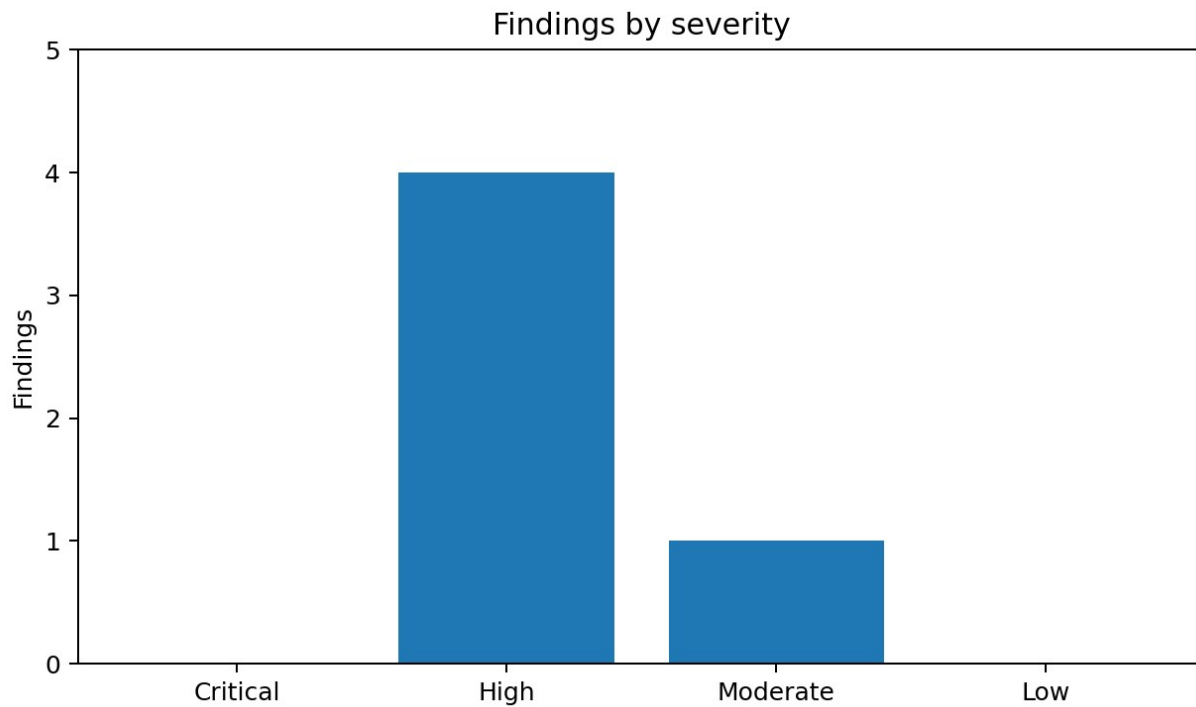
Four High-rated findings affect control areas capable of increasing the likelihood or impact of unauthorised access, delayed detection, extended recovery or exploitability of customer-data systems. One Moderate finding concerns stale assurance over a material CRM processor. The underlying technical issues intentionally reuse canonical MTFS IDs already used in other assurance lenses.



Priority findings

ID	Finding	Issue	Rating	Owner	Target
GDPR-FND-001	Legacy privileged access path does not consistently enforce MFA	MT-IAM-001	High	Director of IAM	2026-10-31
GDPR-FND-002	Central monitoring does not cover two critical personal-data systems	MT-LOG-001	High	Head of Security Operations	2026-11-15
GDPR-FND-003	Critical core-banking restore testing evidence is incomplete	MT-RES-001	High	Director of Cloud & Infrastructure	2026-10-15
GDPR-FND-004	Ongoing security assurance for a material CRM processor is overdue	MT-TPR-001	Moderate	Head of Third-Party Risk	2026-12-15
GDPR-FND-005	Critical and high vulnerabilities exceed approved remediation windows	MT-VUL-001	High	Head of Vulnerability Management	2026-10-31

Risk concentration



The ratings are historical assessment ratings. Planned remediation does not reduce them; closure requires evidence-backed retesting.

Management priorities and next steps

GDPR-FND-001 - High: Retire or isolate the legacy path; enforce phishing-resistant or otherwise risk-appropriate MFA for privileged interactive access; define tightly controlled emergency-account exceptions; and monitor/report any remaining bypasses until closure.

GDPR-FND-002 - High: Risk-rank and onboard both sources to central monitoring, implement priority privileged/admin activity detections, confirm retention and time synchronisation, and add quarterly reconciliation of critical systems to SIEM coverage.

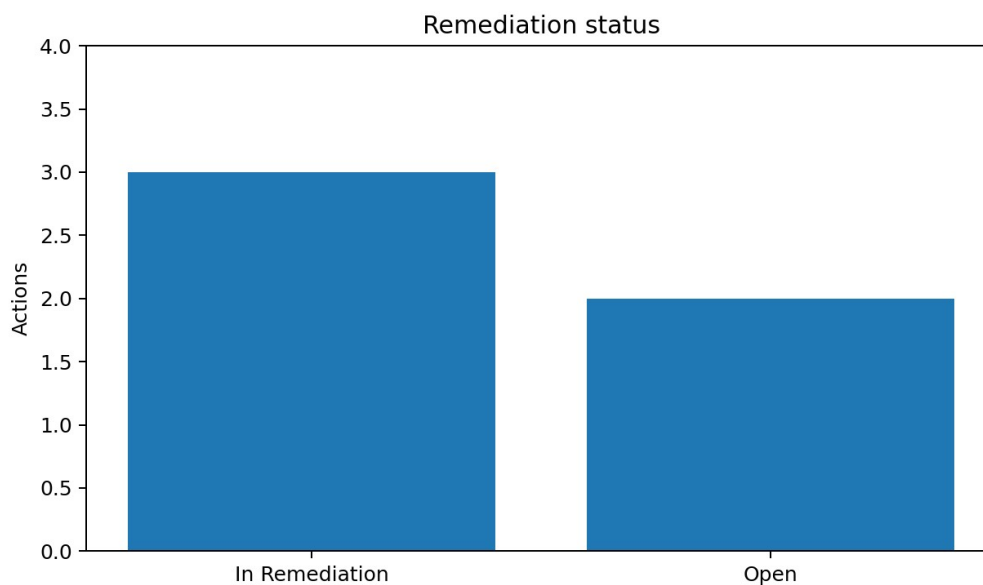
GDPR-FND-003 - High: Complete an end-to-end core-banking restore exercise against approved recovery objectives, record data-integrity validation, and require formal risk acceptance/escalation when critical restore tests are deferred.

GDPR-FND-004 - Moderate: Complete a refreshed risk-based security assessment of Northbridge, obtain closure evidence for the prior penetration-test action, record subprocessor/transfer changes, and integrate privacy-processor review dates into the enterprise third-party assurance schedule.

GDPR-FND-005 - High: Prioritise the four Critical items, enforce owner escalation before SLA breach, require documented time-bound exceptions with compensating controls, and introduce weekly aged-vulnerability reporting for restricted-data assets.

Supporting-process results

The breach-readiness tabletop reached a reasoned reportability decision and a hypothetical notification package 26 hours 30 minutes after awareness. The selected rights-request sample was timely under the documented workflow, including DUAA 2025 clarification timing and reasonable/proportionate-search documentation. Two restricted-transfer samples used a UK Addendum or UK IDTA plus a documented TRA/data protection test; no transfer finding was raised.



Scope boundary

This is security/control assurance supporting UK GDPR for MT-ENT-002. It excludes a full legal compliance review, PECR, EEA/DORA obligations, certification and financial-statement ITGC testing.

Portfolio Case Study - fictional/synthetic MTFS content only. Methodology demonstration; not a real client audit, certification audit, legal opinion or regulatory assurance engagement. | Page 3